

SOFTWARE REQUIREMENTS SPECIFICATION

Financial Fraud Detection & Prevention System

Prepared in accordance with:

IEEE Std 830-1998 (Software Requirements Specifications)
ISO/IEC/IEEE 29148:2018 (Requirements Engineering)

Document Attribute	Details
Document ID	SRS-FDS-2025-001
Version	1.0 (Initial Release)
Date Issued	June 2025
Classification	Confidential — Internal Use Only
Prepared By	Systems Engineering & Compliance Team
Reviewed By	Chief Risk Officer, IT Security Lead
Approved By	Chief Technology Officer
Next Review	December 2025

This document is classified CONFIDENTIAL. Distribution is restricted to authorised personnel involved in the design, development, audit, or regulatory review of the Financial Fraud Detection System. Unauthorised disclosure is prohibited.

Revision History

Version	Date	Author	Description of Change
1.0	June 2025	Systems Engineering Team	Initial document release for stakeholder review
0.9	May 2025	Systems Engineering Team	Internal draft — compliance review
0.8	April 2025	Business Analyst	First complete draft of functional requirements

Table of Contents

1. Introduction	4
1.1 Purpose	4
1.2 Scope	4
1.3 Definitions, Acronyms, and Abbreviations	4
1.4 References	5
1.5 Document Overview	6
2. Overall Description	6
2.1 Product Perspective	6
2.2 Product Functions Summary	7
2.3 User Classes and Characteristics	7
2.4 Operating Environment	8
2.5 Constraints and Assumptions	8
3. Functional Requirements	9
3.1 FR-1: Real-Time Transaction Monitoring	9
3.2 FR-2: Machine Learning & Rule-Based Detection	10
3.3 FR-3: Identity Verification & KYC/AML Compliance	11
3.4 FR-4: Case Management & Investigation Workflow	12
3.5 FR-5: Alerts, Notifications & Reporting	13
3.6 FR-6: Audit Trail & Regulatory Reporting	13
4. Non-Functional Requirements	14
4.1 Performance Requirements	14
4.2 Security Requirements	15
4.3 Availability and Reliability	15
4.4 Scalability	16
4.5 Usability	16
5. Compliance & Regulatory Requirements	16
6. System Interfaces	18
7. Data Requirements	19
8. Traceability Matrix	20
9. Appendix A — Glossary	21
10. Appendix B — References	22

1. Introduction

1.1 Purpose

This Software Requirements Specification (SRS) defines the functional, non-functional, and compliance requirements for the Financial Fraud Detection and Prevention System (FFDPS). It has been prepared in accordance with IEEE Std 830-1998 (IEEE Recommended Practice for Software Requirements Specifications) and ISO/IEC/IEEE 29148:2018 (Systems and Software Engineering — Life Cycle Processes — Requirements Engineering).

The intended audience for this document includes:

- Software engineers and architects responsible for system design and implementation
- Quality assurance and testing teams
- Compliance and legal officers responsible for regulatory alignment
- Senior management and project sponsors
- Third-party auditors and regulatory reviewers

1.2 Scope

The Financial Fraud Detection and Prevention System (FFDPS) is a software platform designed to detect, investigate, prevent, and report fraudulent activity across financial transaction channels in real time. The system targets financial institutions, fintech companies, payment processors, and online merchants.

The FFDPS will provide:

- Real-time transaction monitoring and risk scoring
- Machine learning (ML) and rule-based anomaly detection
- Know Your Customer (KYC) and Anti-Money Laundering (AML) compliance workflows
- Automated case management for fraud investigations
- Regulatory reporting aligned with FATF, PCI DSS v4.0.1, PSD2, and GDPR requirements
- Audit trails and evidence management for legal proceedings

The system does NOT include: core banking transaction processing, customer-facing banking interfaces, or tax reporting systems. Integration with those systems is defined under Section 6 (System Interfaces).

1.3 Definitions, Acronyms, and Abbreviations

Term / Acronym	Definition
----------------	------------

AML	Anti-Money Laundering — regulatory framework to prevent proceeds of crime entering the financial system
APP Fraud	Authorised Push Payment fraud — victim is tricked into authorising a payment to a fraudster (accounted for 40% of all fraud losses in 2022, per PSR)
CDE	Cardholder Data Environment — systems that store, process, or transmit payment card data (PCI DSS scope)
FATF	Financial Action Task Force — intergovernmental body setting global AML/CFT standards
FFDPS	Financial Fraud Detection and Prevention System — the system described in this SRS
FIU	Financial Intelligence Unit — national body receiving suspicious activity reports
KYC	Know Your Customer — identity verification process for onboarding financial customers
ML	Machine Learning — statistical modelling technique used for anomaly detection
MFA	Multi-Factor Authentication — authentication using two or more independent factors
PCI DSS	Payment Card Industry Data Security Standard — currently v4.0.1 (mandatory since Dec 2024)
PSD2	Payment Services Directive 2 — EU regulation requiring Strong Customer Authentication
PSR	Payment Systems Regulator (UK) — introduced 50/50 liability rules for APP fraud (2024)
SAR	Suspicious Activity Report — regulatory filing to FIU for suspected money laundering
SIEM	Security Information and Event Management — centralised log aggregation and analysis
SRS	Software Requirements Specification — this document
UEBA	User and Entity Behaviour Analytics — ML-based detection of anomalous user behaviour

1.4 References

The following standards, regulations, and industry publications form the normative and informative basis for this SRS. All requirements traceable to these references are annotated in Section 3 and Section 5.

Ref. ID	Standard / Regulation	Publisher	Year
---------	-----------------------	-----------	------

[R1]	IEEE Std 830-1998: Recommended Practice for Software Requirements Specifications	IEEE	1998
[R2]	ISO/IEC/IEEE 29148:2018: Systems and Software Engineering — Requirements Engineering (confirmed current 2024)	ISO / IEEE	2018
[R3]	PCI DSS v4.0.1: Payment Card Industry Data Security Standard (mandatory from Dec 2024; v3.2.1 retired)	PCI SSC	2024
[R4]	FATF Recommendations: International Standards on Combating Money Laundering and Terrorism Financing	FATF	2023
[R5]	EU Fourth Anti-Money Laundering Directive (AMLD4): Directive (EU) 2015/849	European Parliament	2015
[R6]	Regulation (EU) 2016/679 — General Data Protection Regulation (GDPR)	European Parliament	2016
[R7]	Payment Services Directive 2 (PSD2): Directive (EU) 2015/2366 (Strong Customer Authentication)	European Parliament	2015
[R8]	NIST Cybersecurity Framework (CSF) 2.0 — Financial Services Sector Profile	NIST	2024
[R9]	NIST SP 800-63-4: Digital Identity Guidelines (finalised late 2024)	NIST	2024
[R10]	PSR: APP Fraud 50/50 Liability Rules (effective 2024)	UK Payment Systems Regulator	2024
[R11]	EBA CLEARING FPAD Pilot (Fraud Pattern and Anomaly Detection, launched Sep 2023)	EBA CLEARING	2023
[R12]	FTC Consumer Sentinel Network: Consumers Lost \$8.8 Billion to Fraud in 2022	US FTC	2023
[R13]	Lucinity: Evaluating Fraud Management Software (May 2024)	Lucinity	2024
[R14]	Mastercard: Four Must-Have SaaS Capabilities for Effective Fraud Detection (Jan 2026)	Mastercard	2026
[R15]	Global Fraud Detection and Prevention Market: \$52.82B (2024) projected to \$255.39B (2032)	Lucinity / Market Research	2024

1.5 Document Overview

This SRS is organised as follows:

- Section 2 provides the overall product description, context, and user characteristics.
- Section 3 defines detailed functional requirements grouped by system capability.
- Section 4 specifies non-functional requirements (performance, security, reliability).
- Section 5 maps compliance and regulatory obligations to system requirements.

- Section 6 defines external system interfaces and APIs.
- Section 7 describes data requirements, retention, and classification.
- Section 8 provides the requirements traceability matrix.
- Appendices contain the glossary and full reference list.

2. Overall Description

2.1 Product Perspective

The FFDPS is a new, standalone software platform that integrates with existing financial infrastructure. It is not a replacement for core banking systems but operates as a dedicated fraud intelligence and prevention layer.

The system interfaces with:

- Core banking transaction processing engines (via REST API or message queue)
- Payment gateway providers and card networks (e.g., Visa, Mastercard Consumer Fraud Risk [R14])
- Identity verification and KYC data providers
- National Financial Intelligence Units (FIU) for SAR submission
- SIEM platforms for centralised security logging (PCI DSS v4.0.1 Req. 10.4.1.1 [R3])
- Customer notification services (email, SMS) for fraud alerts

Industry context: The global fraud detection and prevention market was valued at \$52.82 billion in 2024 and is projected to reach \$255.39 billion by 2032 [R15]. The UK PSR's 2024 APP fraud liability rules [R10] and PCI DSS v4.0.1 (mandatory December 2024 [R3]) are primary regulatory drivers for this system.

2.2 Product Functions Summary

The FFDPS will provide the following major functional capabilities:

1. Real-Time Transaction Monitoring — analyse every transaction at the moment of initiation using configurable risk rules and ML scoring
2. Machine Learning Anomaly Detection — identify unusual patterns (transaction size, location, frequency, behavioural deviation) using trained ML models and UEBA
3. Identity Verification and KYC/AML Compliance — automated customer due diligence aligned with FATF recommendations [R4] and AMLD4 [R5]
4. Fraud Case Management — structured investigation workflow with task assignment, evidence capture, and case resolution tracking
5. Alerts and Notifications — real-time alerts to analysts and customers for suspicious activities
6. Regulatory Reporting — automated SAR generation, audit trails, and PCI DSS compliance reporting
7. Administration and Configuration — rule engine management, user access control, and system configuration

2.3 User Classes and Characteristics

User Class	Description	Technical Level	Primary Functions Used
------------	-------------	-----------------	------------------------

Fraud Analyst	Day-to-day investigation of flagged transactions and cases	Intermediate	Case management, alert review, evidence capture, SAR filing
Compliance Officer	Regulatory oversight, SAR submission, AML monitoring	Intermediate	Regulatory reports, KYC workflows, audit trails
System Administrator	Configuration of rules, user management, integration monitoring	High	Rule engine, user admin, system config, API management
Senior Investigator	Complex fraud scheme investigation, cross-case analysis	High	Advanced analytics, case escalation, network analysis
Auditor (Internal/External)	Review of system controls and compliance evidence	Low–Intermediate	Read-only audit logs, compliance reports, traceability records
IT Security Engineer	System security monitoring, vulnerability management, SIEM integration	High	Security dashboards, log review, PCI DSS controls

2.4 Operating Environment

The FFDPS shall operate in the following environment:

- Deployment: Cloud-native (private cloud or hybrid) with container orchestration (Kubernetes). On-premises deployment must be supported for institutions with data residency requirements.
- Operating Systems: Server workloads on Linux (Ubuntu 22.04 LTS or RHEL 8+). Client interfaces via modern web browsers (Chrome 120+, Firefox 121+, Edge 120+).
- Database: Relational database for structured transaction data; time-series database for behavioural analytics; document store for case evidence.
- Network: All data in transit encrypted with TLS 1.2 or higher (PCI DSS v4.0.1 Req. 4 [R3]). Network segmentation of the Cardholder Data Environment (CDE) required.
- Availability: 99.99% uptime SLA during business-critical hours (see Section 4.3).

2.5 Constraints and Assumptions

Constraints

- The system must comply with PCI DSS v4.0.1 [R3] (effective December 2024) in all environments that store, process, or transmit cardholder data.
- Personal data processed within the EU/EEA must comply with GDPR [R6]. Data erasure capabilities must be available for right-to-erasure requests.
- SAR submissions must meet the format and timeline requirements of the relevant national FIU.
- All ML models used for risk scoring must be explainable (whitebox or explainable AI) to satisfy regulatory audit requirements.

- Passwords for all CDE-accessing accounts must be a minimum of 12 characters with numeric and alphabetic complexity (PCI DSS v4.0.1 Req. 8.3.6 [R3]).

Assumptions

- The organisation has existing core banking infrastructure with accessible APIs or message queues.
- Sufficient labelled historical transaction data (minimum 24 months) is available for initial ML model training.
- The organisation will designate qualified staff for system administration, fraud analysis, and compliance oversight.
- Regulatory requirements may evolve. The system architecture supports rule and model updates without full redevelopment.

3. Functional Requirements

Each requirement is assigned a unique identifier, priority level (Critical / High / Medium), and a reference to the applicable standard or regulation. Requirements marked Critical are mandatory for regulatory compliance or core system operation.

3.1 FR-1: Real-Time Transaction Monitoring

The system shall monitor all financial transactions at the point of initiation and apply risk scoring before transaction completion. This is a primary fraud detection function and is consistent with industry requirements for real-time monitoring [R13] [R14].

Req. ID	Description	Reference / Standard	Priority
FR-1.1	The system shall analyse each transaction in real time, returning a risk score within 300 milliseconds of receipt under normal operating load (up to 10,000 transactions per second).	Mastercard CFR [R14]; FATF Rec. 10 [R4]	Critical
FR-1.2	The system shall evaluate each transaction against a configurable rule engine with parameters including: transaction amount, geographic location, velocity (frequency within time window), merchant category, device fingerprint, and customer behaviour baseline.	FATF Rec. 10 [R4]; PCI DSS Req. 10 [R3]	Critical
FR-1.3	The system shall assign a risk score (0–1000) to each transaction, categorised as Low (0–300), Medium (301–600), High (601–850), or Critical (851–1000).	Lucinity [R13]; SEON [R7-ref]	Critical
FR-1.4	Transactions scoring above the High threshold (>600) shall trigger an automated hold or step-up authentication request in accordance with PSD2 Strong Customer Authentication requirements [R7].	PSD2 Art. 97 [R7]	Critical
FR-1.5	The system shall support both synchronous (API call-response) and asynchronous (message queue) integration modes for transaction ingestion.	IEEE 830 §3.1 [R1]	High
FR-1.6	The system shall provide a real-time dashboard displaying live transaction volumes, active alerts, and system health metrics accessible to authorised analysts.	Lucinity [R13]	High

FR-1.7	The system shall log all transaction scoring events with timestamps, input parameters, applied rules, and resulting score for audit purposes.	PCI DSS Req. 10.2 [R3]; GDPR Art. 5(2) [R6]	Critical
--------	---	--	----------

3.2 FR-2: Machine Learning and Rule-Based Detection

The FFDPS shall employ a hybrid detection approach combining static rule-based logic (for known fraud patterns) with adaptive ML models (for emerging and novel fraud schemes). According to Lucinity (2024) [R13], advanced analytics and AI using ML algorithms are essential for identifying patterns and anomalies that may indicate fraud, thereby staying ahead of evolving fraudulent schemes.

Req. ID	Description	Reference / Standard	Priority
FR-2.1	The system shall include a supervised ML model trained on labelled historical transaction data to classify transactions as fraudulent or legitimate, with an initial target precision of at least 90% and recall of at least 85% on the training holdout set.	Lucinity [R13]; Mastercard [R14]	Critical
FR-2.2	The system shall include an unsupervised anomaly detection model to identify novel fraud patterns not captured by existing rules or the supervised model.	Mastercard CFR [R14]; Spec (2024) [R11-ref]	High
FR-2.3	The system shall implement User and Entity Behaviour Analytics (UEBA) to establish a behavioural baseline for each customer and flag deviations (e.g., login from new device, unusual transaction time, new geographic location).	NIST CSF 2.0 [R8]; PCI DSS Req. 10 [R3]	High
FR-2.4	The system shall support a configurable rule engine allowing compliance officers and senior investigators to create, modify, enable, or disable fraud rules without requiring software deployment.	Lucinity [R13]; SEON [R7-ref]	High
FR-2.5	All ML models shall be explainable: the system shall generate a human-readable explanation for each fraud flag, listing the top contributing factors (e.g., 'Transaction amount 450% above 30-day average; new device; high-risk merchant category').	FATF Guidance on AI [R4]; regulatory audit requirement	Critical
FR-2.6	The system shall support automated model retraining on a scheduled basis (minimum: monthly) using newly labelled data, with version-controlled model deployment and rollback capability.	Mastercard [R14]; Lucinity [R13]	High

FR-2.7	The system shall maintain a model performance dashboard showing precision, recall, F1-score, false positive rate, and false negative rate, updated after each retraining cycle.	IEEE 830 §3.2 [R1]	Medium
--------	---	--------------------	--------

3.3 FR-3: Identity Verification and KYC/AML Compliance

The system shall support Know Your Customer (KYC) and Anti-Money Laundering (AML) compliance workflows. Per FATF Recommendations [R4] and EU AMLD4 [R5], financial institutions are required to implement risk-based AML policies and procedures including KYC and KYB due diligence and ongoing customer monitoring. SEON (2025) [R7-ref] confirms that KYC compliance is one of the most fundamental ways a fraud prevention system helps meet regulatory requirements.

Req. ID	Description	Reference / Standard	Priority
FR-3.1	The system shall perform automated identity verification at customer onboarding using document verification (passport, national ID) and biometric comparison, achieving a minimum 99% document verification accuracy rate consistent with industry benchmarks.	FATF Rec. 10 [R4]; AMLD4 Art. 13 [R5]; YouVerify benchmark [R12-ref]	Critical
FR-3.2	The system shall screen customers against global sanctions lists, Politically Exposed Persons (PEP) registers, and adverse media sources at onboarding and on a recurring daily basis.	FATF Rec. 12 [R4]; AMLD4 Art. 18–24 [R5]	Critical
FR-3.3	The system shall conduct customer risk assessment and assign a risk category (Low / Medium / High / Very High) that determines the level of Enhanced Due Diligence (EDD) applied.	FATF Rec. 1 [R4]; Flagright [R12]	Critical
FR-3.4	The system shall flag transactions to high-risk countries (as defined by FATF's non-cooperative jurisdictions list) for enhanced review.	FATF Rec. 19 [R4]	Critical
FR-3.5	The system shall monitor transactions for AML typologies including: structuring (smurfing), layering, large cash transactions, and mule account activity, consistent with Flagright's real-time monitoring approach [R12].	FATF Rec. 20 [R4]; AMLD4 [R5]	High
FR-3.6	The system shall generate and maintain KYC records with a full audit trail, retaining records for a minimum of 5 years from the end of the customer relationship	AMLD4 Art. 40 [R5]; GDPR Art. 5(1)(e) [R6]	Critical

	(AMLD4 Art. 40 [R5]) or as required by local jurisdiction.		
--	--	--	--

3.4 FR-4: Case Management and Investigation Workflow

When fraud is detected, a structured case management system shall support the full investigation lifecycle. Per Mastercard (2026) [R14], fraud case management provides a centralised platform for tracking and managing fraud incidents, capturing user information, transaction details, and investigation findings. Lucinity (2024) [R13] identifies streamlined workflows and automated routing as essential for scaling fraud operations.

Req. ID	Description	Reference / Standard	Priority
FR-4.1	The system shall automatically create a fraud case for any transaction or customer event that exceeds the High risk threshold, or for any transaction manually escalated by an analyst.	Lucinity [R13]; Mastercard [R14]	Critical
FR-4.2	Each case shall include: unique case ID, creation timestamp, risk score, transaction details, customer profile, contributing ML factors, linked historical cases, and assigned investigator.	IEEE 830 §3 [R1]; Lucinity [R13]	Critical
FR-4.3	The system shall support workflow automation including: automatic routing to available analysts based on workload, SLA countdown timers, escalation triggers if case exceeds defined response time.	Lucinity [R13]	High
FR-4.4	Investigators shall be able to add notes, upload evidence files, link related cases, and record decisions within the case record.	IEEE 830 §3 [R1]	High
FR-4.5	The system shall support case statuses: Open, Under Investigation, Pending Customer Contact, Pending SAR Filing, Closed — Confirmed Fraud, Closed — False Positive.	FATF Rec. 20 [R4]	High
FR-4.6	The system shall provide network visualisation of linked cases, shared customer attributes, and transaction chains to support complex fraud scheme investigation.	Lucinity [R13]; EBA CLEARING FPAD [R11]	Medium
FR-4.7	The system shall allow case sharing with other authorised financial institutions through a secure, permission-controlled interface, consistent with collaborative	Salv Bridge [R5-ref]; FATF Rec. 40 [R4]	Medium

	fraud investigation models (e.g., Salv Bridge demonstrates fund recovery rates up to 80% through institution collaboration).		
--	--	--	--

3.5 FR-5: Alerts, Notifications, and Reporting

Req. ID	Description	Reference / Standard	Priority
FR-5.1	The system shall send real-time alerts to fraud analysts via the dashboard, email, and configurable webhook for all Critical-risk transactions.	Mastercard [R14]; PCI DSS Req. 12.10 [R3]	Critical
FR-5.2	The system shall send automated customer notifications (SMS and/or email) for transactions flagged as Critical, requesting confirmation or authorisation, subject to organisational policy.	PSD2 SCA [R7]; PSR liability rules [R10]	High
FR-5.3	The system shall generate a daily fraud summary report (total alerts, confirmed fraud, false positive rate, cases opened/closed, financial exposure) available to authorised management users.	PCI DSS Req. 12 [R3]; Lucinity [R13]	High
FR-5.4	The system shall generate an automated SAR draft when cumulative confirmed fraud indicators meet jurisdictional filing thresholds, pre-populated with required data fields.	FATF Rec. 20 [R4]; AMLD4 Art. 33 [R5]	Critical
FR-5.5	Alert thresholds (score cutoff, transaction amount, velocity triggers) shall be configurable by authorised administrators without system redeployment.	IEEE 830 §3 [R1]; Lucinity [R13]	High

3.6 FR-6: Audit Trail and Regulatory Reporting

Req. ID	Description	Reference / Standard	Priority
FR-6.1	The system shall maintain an immutable, append-only audit log of all actions performed by all users, including: user ID, timestamp, action type, affected record, and IP address.	PCI DSS Req. 10.2 [R3]; GDPR Art. 5(2) [R6]	Critical
FR-6.2	Audit logs shall be reviewed via automated SIEM tools. PCI DSS v4.0.1 Req. 10.4.1.1 [R3] mandates automated audit log reviews for all CDE components.	PCI DSS Req. 10.4.1.1 [R3]	Critical

FR-6.3	The system shall produce a PCI DSS compliance report on demand, mapping system controls to PCI DSS v4.0.1 requirements.	PCI DSS Req. 12 [R3]	High
FR-6.4	Audit logs shall be retained for a minimum of 12 months, with at least 3 months immediately available for analysis (PCI DSS Req. 10.7 [R3]).	PCI DSS Req. 10.7 [R3]	Critical
FR-6.5	The system shall support data subject access requests (DSAR) and right-to-erasure requests as required by GDPR [R6], with a documented process to identify and anonymise personal data while preserving fraud evidence integrity.	GDPR Art. 15–17 [R6]	High

4. Non-Functional Requirements

4.1 Performance Requirements

Req. ID	Metric	Target	Reference
NFR-P1	Transaction risk scoring latency (p99)	≤ 300 ms	Mastercard [R14]
NFR-P2	Peak transaction throughput	≥ 10,000 TPS sustained	Lucinity [R13]
NFR-P3	Dashboard page load time	< 2 seconds (90th percentile)	IEEE 830 §3.2 [R1]
NFR-P4	Case creation latency after trigger	≤ 1 second	Lucinity [R13]
NFR-P5	Alert delivery latency to analyst dashboard	≤ 5 seconds from detection	PCI DSS Req. 12 [R3]
NFR-P6	Batch ML model scoring (end-of-day review)	Complete within 2 hours for 1M transactions	IEEE 830 [R1]

4.2 Security Requirements

Security requirements are governed primarily by PCI DSS v4.0.1 [R3] (mandatory from December 2024), NIST CSF 2.0 [R8], and NIST SP 800-63-4 [R9].

Req. ID	Requirement	Reference
NFR-S1	Multi-Factor Authentication (MFA) is mandatory for all user accounts accessing the FFDPS and all accounts with access to the CDE (PCI DSS v4.0.1 Req. 8.3.1 became mandatory March 2025).	PCI DSS Req. 8.3.1 [R3]; NIST SP 800-63-4 [R9]
NFR-S2	Passwords for CDE-accessing accounts must be minimum 12 characters including both numeric and alphabetic characters (PCI DSS v4.0.1 Req. 8.3.6).	PCI DSS Req. 8.3.6 [R3]
NFR-S3	All cardholder data must be encrypted at rest using AES-256 and in transit using TLS 1.2 or higher.	PCI DSS Req. 3 and 4 [R3]
NFR-S4	The CDE must be network-segmented from non-CDE systems. Firewall rules must enforce boundary controls and log all traversal attempts.	PCI DSS Req. 1 [R3]
NFR-S5	Role-Based Access Control (RBAC) must enforce least-privilege access. Human accounts must be reviewed every six months; system accounts per targeted risk analysis (PCI DSS v4.0.1 Req. 7.2.4–7.2.5).	PCI DSS Req. 7.2.4–7.2.5 [R3]; NIST CSF 2.0 [R8]

NFR-S6	Automated vulnerability scanning must be performed quarterly, and penetration testing annually at minimum (PCI DSS Req. 11).	PCI DSS Req. 11 [R3]
NFR-S7	The system must detect and alert on unauthorised changes to payment pages and scripts within a maximum of one week (PCI DSS v4.0.1 Req. 11.6.1, mandatory March 2025).	PCI DSS Req. 11.6.1 [R3]
NFR-S8	All cryptographic keys must be managed in FIPS 140-2 Level 3 validated Hardware Security Modules (HSMs).	PCI DSS Req. 3.7 [R3]; NIST [R8]

4.3 Availability and Reliability

Req. ID	Requirement	Target
NFR-A1	System availability (excluding planned maintenance)	99.99% per calendar month
NFR-A2	Maximum unplanned downtime per year	< 52 minutes
NFR-A3	Recovery Time Objective (RTO) — full system recovery after major failure	< 1 hour
NFR-A4	Recovery Point Objective (RPO) — maximum data loss in event of failure	< 5 minutes
NFR-A5	Automated failover to standby region	< 30 seconds
NFR-A6	Data backup frequency	Continuous (real-time replication) + daily snapshots

4.4 Scalability

- The system shall scale horizontally to handle transaction volumes up to 50,000 TPS without architectural changes.
- The system shall support onboarding of new financial institution clients without system reconfiguration, using multi-tenant data isolation.
- ML model training pipelines shall scale to process datasets of at least 500 million transactions.
- The rule engine shall support a minimum of 10,000 active fraud rules without performance degradation.

4.5 Usability

- The fraud analyst dashboard shall present all information required for case triage on a single screen, without requiring more than three clicks to reach any case detail.
- The system shall provide onboarding documentation, user manuals, and in-application contextual help.
- The user interface shall comply with WCAG 2.1 Level AA accessibility standards.

- The system shall support English as the primary interface language, with localisation capability for additional languages.

5. Compliance and Regulatory Requirements

This section maps the key regulatory obligations to system requirements. All requirements in this section are classified Critical unless otherwise stated. The regulatory landscape is continuously evolving; the system architecture shall support rapid configuration updates to respond to new requirements without full redevelopment [R13].

Regulation / Standard	Key Obligation	System Requirement(s)	Notes
PCI DSS v4.0.1 [R3]	Protect cardholder data; continuous monitoring; MFA for all CDE accounts; automated log review; 12-char passwords. Mandatory December 2024.	NFR-S1, NFR-S2, NFR-S3, NFR-S4, NFR-S5, NFR-S7, FR-6.1, FR-6.2, FR-6.4	PCI DSS v4.0.1 is sole active standard since Dec 2024 [R3]
FATF Recommendations [R4]	Risk-based AML approach; customer due diligence; transaction monitoring; SAR reporting to FIU.	FR-3.1–FR-3.6, FR-4.4, FR-5.4	Applies globally; extended to fintechs, BNPL operators [R7-ref]
EU AMLD4 [R5]	KYC/KYB due diligence; PEP screening; SAR to FIU; records retained 5 years.	FR-3.1, FR-3.2, FR-3.6, FR-5.4	EU-specific; national transposition may vary
GDPR [R6]	Lawful basis for processing; data minimisation; right of erasure; records of processing activities.	FR-6.5, FR-3.6, NFR-S3	Applies to EU/EEA personal data; 72-hour breach notification
PSD2 [R7]	Strong Customer Authentication (SCA) for online payments; fraud exemptions possible with low-risk tools.	FR-1.4, FR-5.2	SCA exemption available for transactions with low fraud rate
UK PSR APP Fraud Rules [R10]	50/50 liability between sending and receiving PSPs for APP fraud losses (effective 2024).	FR-1.1, FR-1.2, FR-5.2	Applies to UK PSPs; drives need for real-time detection before money leaves account
NIST CSF 2.0 [R8]	Govern, Identify, Protect, Detect, Respond, Recover functions; Financial Services Sector Profile.	NFR-S1, NFR-S5, NFR-S6, FR-6.1	De facto global standard adopted by EU/Asia institutions for interoperability
NIST SP 800-63-4 [R9]	Authentication assurance levels; guidance on passkeys, FIDO-based and phishing-resistant MFA (finalised 2024).	NFR-S1, NFR-S2	Reference for MFA implementation design

Regulatory note: The EBA CLEARING Fraud Pattern and Anomaly Detection (FPAD) pilot launched in September 2023 with nine banks across six countries [R11]. The FFDPS architecture shall be designed to support future participation in collaborative fraud intelligence networks consistent with this model.

6. System Interfaces

6.1 External System Interfaces

Interface	Direction	Protocol / Format	Purpose	Security
Core Banking System	Inbound	REST API / ISO 20022 JSON	Transaction event ingestion for real-time monitoring	TLS 1.3; mutual TLS authentication
Payment Gateway / Card Network	Inbound	REST API / ISO 8583	Card transaction data and authorisation requests	TLS 1.3; API key + MFA
KYC / Identity Provider	Bidirectional	REST API / JSON	Document verification and biometric matching results	TLS 1.3; OAuth 2.0
Sanctions & PEP Database	Inbound	REST API / XML or JSON	Daily sanctions list and PEP register updates	TLS 1.3; API key
National FIU (SAR portal)	Outbound	Secure file upload / XBRL	Submission of Suspicious Activity Reports	FIU-mandated secure channel
SIEM Platform	Outbound	Syslog / CEF over TLS	Centralised audit log streaming for PCI DSS Req. 10 compliance	TLS 1.2+; certificate authentication
Notification Service	Outbound	REST API (email/SMS gateway)	Customer fraud alerts and analyst notifications	TLS 1.3; API key
Collaborative Fraud Network (optional)	Bidirectional	REST API	Shared fraud intelligence with partner institutions	TLS 1.3; OAuth 2.0; data sharing agreement required

6.2 User Interfaces

- Web-based analyst dashboard: responsive single-page application (SPA), supporting screens from 1280px width and above.
- Administration console: separate access-controlled interface for system configuration, rule management, and user administration.
- Compliance reporting portal: read-only interface for compliance officers and auditors, with export to PDF and CSV.
- Mobile interface: read-only alert notification and case status view for senior investigators (iOS 16+ and Android 13+).

7. Data Requirements

7.1 Data Classification

Data Category	Classification	Retention Period	Reference
Cardholder data (PAN, CVV, expiry)	Restricted — PCI Scope	Minimum required; PAN masked or tokenised in non-CDE systems	PCI DSS Req. 3 [R3]
Transaction records	Confidential	Minimum 5 years (AML record-keeping)	AMLD4 Art. 40 [R5]
KYC documents and identity records	Restricted	5 years after end of customer relationship	AMLD4 Art. 40 [R5]; GDPR [R6]
Audit logs (user actions, system events)	Confidential	Minimum 12 months; 3 months immediately accessible	PCI DSS Req. 10.7 [R3]
ML model training data	Confidential	Retained while model is in use + 2 years post-retirement	IEEE 830 [R1]
SAR filings and supporting evidence	Restricted	As mandated by relevant FIU (typically 5–7 years)	AMLD4 Art. 40 [R5]; FATF Rec. 20 [R4]
Anonymised / aggregated analytics data	Internal	Indefinite (no personal data)	GDPR Art. 5(1)(b) [R6]

7.2 Data Integrity and Quality

- All transaction data ingested shall be validated against a defined schema before processing. Malformed records shall be rejected with an error log entry.
- Data integrity checks (checksums) shall be applied to audit logs to detect tampering (PCI DSS Req. 10.3 [R3]).
- Sensitive cardholder data shall be tokenised at the point of ingestion wherever full PAN is not required for fraud analysis.
- The system shall implement data minimisation principles: only data fields necessary for fraud detection and regulatory compliance shall be collected and retained (GDPR Art. 5(1)(c) [R6]).

8. Requirements Traceability Matrix

The following matrix maps system requirements to the regulatory standards that mandate them. This supports compliance audits and verification activities.

Requirement ID	Requirement Summary	IEEE 830 [R1]	PCI DSS [R3]	FATF [R4]	AMLD4 [R5]	GDPR [R6]	PSD2 [R7]
FR-1.1	Real-time scoring <300ms	§3.2	Req. 10	Rec. 10	--	--	--
FR-1.4	SCA trigger >600 risk score	§3.1	--	--	--	--	Art. 97
FR-1.7	Transaction event audit log	§3.2	Req. 10.2	--	--	Art. 5(2)	--
FR-2.1	Supervised ML model (≥90% precision)	§3.2	--	--	--	--	--
FR-2.5	Explainable AI for fraud flags	§3.2	--	Guidance	--	--	--
FR-3.1	Automated identity verification	§3.1	--	Rec. 10	Art. 13	--	--
FR-3.2	Sanctions and PEP screening	§3.1	--	Rec. 12	Art. 18	--	--
FR-3.6	KYC records retained 5 years	§3.1	--	--	Art. 40	Art. 5(1)(e)	--
FR-5.4	Automated SAR draft generation	§3.1	--	Rec. 20	Art. 33	--	--
FR-6.1	Immutable audit log	§3.2	Req. 10.2	--	--	Art. 5(2)	--
FR-6.2	Automated SIEM log review	§3.2	Req. 10.4.1.1	--	--	--	--
FR-6.4	Audit log 12-month retention	§3.2	Req. 10.7	--	--	--	--
NFR-S1	MFA for all accounts	§3.3	Req. 8.3.1	--	--	--	--
NFR-S2	12-char minimum passwords	§3.3	Req. 8.3.6	--	--	--	--
NFR-S3	AES-256 encryption at rest	§3.3	Req. 3 & 4	--	--	Art. 32	--

Appendix A — Glossary

This appendix provides extended definitions for technical and regulatory terms used throughout this document.

Term	Extended Definition
Authorised Push Payment (APP) Fraud	A fraud type where the victim is manipulated (e.g., via impersonation, social engineering) into authorising a payment to an account controlled by a fraudster. The UK PSR reported APP fraud accounted for 40% of all UK fraud losses in 2022 [R10]. Under 2024 PSR rules, liability is shared 50/50 between sending and receiving payment service providers.
Behavioural Baseline	A statistical profile of a customer's normal transaction behaviour (amounts, times, locations, devices, merchant categories) used by UEBA systems to detect anomalous deviations.
Cardholder Data Environment (CDE)	The network segment and systems that store, process, or transmit cardholder data (PANs, CVVs, expiry dates). PCI DSS v4.0.1 scoping requirements mandate accurate CDE mapping including payment gateways, fraud detection platforms, and backup systems.
Enhanced Due Diligence (EDD)	A more stringent level of customer due diligence applied to high-risk customers (e.g., PEPs, high-risk jurisdictions) under AMLD4 Articles 18–24 and FATF Recommendation 12.
FIDO Authentication	Fast Identity Online — an open authentication standard enabling phishing-resistant MFA using cryptographic keys. Referenced in NIST SP 800-63-4 (2024) [R9] as recommended authentication technology for high-assurance environments.
Mule Account	A bank account used (knowingly or unknowingly) to receive and forward proceeds of fraud. Detection of mule activity is a key AML monitoring requirement under FATF Recommendation 20 and AMLD4.
Suspicious Activity Report (SAR)	A mandatory regulatory filing submitted to the national Financial Intelligence Unit when a financial institution suspects a transaction or customer activity may be related to money laundering, terrorism financing, or other predicate offences.
Tokenisation	A security technique that replaces sensitive data (e.g., a 16-digit PAN) with a non-sensitive surrogate value (token) that retains no exploitable value outside the tokenisation system. PCI DSS v4.0.1 endorses tokenisation as a method to reduce CDE scope.
Whitebox Machine Learning	ML models where the decision logic is interpretable and explainable, as opposed to 'black box' models. Whitebox ML is preferred by regulators and auditors because decision rationale can be documented and challenged.

Appendix B — Full References

All sources cited in this SRS are listed below. All references were verified as current as of June 2025.

8. IEEE Std 830-1998: IEEE Recommended Practice for Software Requirements Specifications. Institute of Electrical and Electronics Engineers, 1998. Available at: <https://ieeexplore.ieee.org/document/720574>
9. ISO/IEC/IEEE 29148:2018: Systems and Software Engineering — Life Cycle Processes — Requirements Engineering. ISO, 2018 (confirmed current 2024). Available at: <https://www.iso.org/standard/72089.html>
10. PCI Security Standards Council: PCI DSS v4.0.1: Payment Card Industry Data Security Standard. PCI SSC, 2024. Sole active standard since December 31, 2024. Available at: <https://www.pcisecuritystandards.org>
11. Financial Action Task Force (FATF): International Standards on Combating Money Laundering and the Financing of Terrorism and Proliferation — The FATF Recommendations. FATF/OECD, Paris, 2023. Available at: <https://www.fatf-gafi.org/recommendations.html>
12. European Parliament: Directive (EU) 2015/849 on the prevention of the use of the financial system for the purposes of money laundering or terrorist financing (Fourth Anti-Money Laundering Directive — AMLD4). Official Journal of the European Union, 2015.
13. European Parliament: Regulation (EU) 2016/679 (General Data Protection Regulation — GDPR). Official Journal of the European Union, 2016. Available at: <https://gdpr-info.eu>
14. European Parliament: Directive (EU) 2015/2366 on payment services in the internal market (PSD2 — Payment Services Directive 2). Official Journal of the European Union, 2015.
15. National Institute of Standards and Technology (NIST): Cybersecurity Framework (CSF) 2.0, including Financial Services Sector Profile. NIST, February 2024. Available at: <https://www.nist.gov/cyberframework>
16. NIST: Special Publication 800-63-4: Digital Identity Guidelines. NIST, 2024. Available at: <https://pages.nist.gov/800-63-4>
17. UK Payment Systems Regulator (PSR): APP Scams: 50/50 Liability Split Policy Statement and Rules (PS23/3). PSR, 2023/2024. Available at: <https://www.psr.org.uk>
18. EBA CLEARING: Fraud Pattern and Anomaly Detection (FPAD) Pilot launched September 2023. Reported in: Salv, 'Best Fraud Detection Software Solutions 2024'. Available at: <https://salv.com/blog/fraud-detection-software-solutions/>
19. US Federal Trade Commission (FTC): Consumer Sentinel Network Data Book 2022 — Consumers Lost a Record \$8.8 Billion to Fraud in 2022. FTC, February 2023. Available at: <https://www.ftc.gov>
20. Lucinity: 'Evaluating Fraud Management Software — Features to Look For.' Lucinity Blog, May 21, 2024. Available at: <https://lucinity.com/blog/evaluating-fraud-management-software-features-to-look-for>
21. Mastercard: 'Four Must-Have SaaS Capabilities for Effective Fraud Detection.' Mastercard Insights, January 22, 2026. Available at: <https://www.mastercard.com/us/en/news-and-trends/Insights/2024/four-essential-saas-features-you-need-in-fraud-detection-software.html>
22. Lucinity / Industry Research: Global Fraud Detection and Prevention Market size — \$52.82 billion (2024) projected to \$255.39 billion (2032). Cited in: Lucinity, May 2024 [as above].

23. SEON: 'Regulatory Requirements for Fraud Prevention — Your Questions Answered.' SEON Blog, April 3, 2025. Available at: <https://seon.io/resources/regulatory-requirements/>
24. Flagright: 'Regulatory Requirements for Effective Fraud Prevention in Fintechs and Neobanks.' Flagright Blog, January 29, 2026. Available at: <https://www.flagright.com/post/regulatory-requirements-for-effective-fraud-prevention-in-fintechs-and-neobanks>
25. HYPR: 'Cybersecurity Regulations for Financial Services for 2026 and Beyond.' HYPR Blog, May 18, 2026. Available at: <https://www.hypr.com/blog/top-financial-services-cybersecurity-regulations>
26. Linford & Company: 'PCI DSS 4.0 Mandatory Requirements: 2025 Compliance Guide.' Linford Blog, July 2025. Available at: <https://linfordco.com/blog/pci-dss-4-0-requirements-guide/>
27. SecureTrust: 'PCI DSS 4.0 Requirements: Key Updates and What They Mean.' SecureTrust Blog, 2025. Available at: <https://www.securetrust.com/blog/pci-4-0-requirements>

END OF DOCUMENT — SRS-FDS-2025-001 v1.0 — CONFIDENTIAL